

LoyaltyBase Role & Permission Audit

Complete read-only audit of System Administrator, Business Owner, Branch Manager, and Staff roles.

Generated from read-only LoyaltyBase audits. No code or database changes are represented in this document.

Table of Contents

1. Validation Summary
2. System Administrator
3. Business Owner
4. Branch Manager
5. Staff
6. Hidden URL and Tenant Isolation
7. Final Summary Matrix

Validation Summary

Check | Result

-----|-----

npm test | Passed - 106/106

npm run lint | Passed

npm run build | Passed with existing Next.js config warnings

The audit inspected route guards, dashboards, role mappings, action files, and automated tests. No code or database records were modified.

System Administrator

Internal role key PLATFORM_OWNER is displayed publicly as System Administrator.

Sidebar: Dashboard, Businesses, Plans, Subscriptions, Invoices, Users, Analytics, Audit Center, Billing Center, Tenant Center, Settings.

Dashboard visibility includes businesses, active subscriptions, monthly revenue, open alerts, customers, programs, failed logins, platform health, and recent activity.

Permissions include full platform administration for businesses, plans, subscriptions, invoices, users, analytics, audit, billing, tenant, settings, database view, and launch readiness.

Verdict: PASS WITH WARNINGS. Access is powerful by design; keep customer PII out of aggregate platform analytics where possible.

Business Owner

Pages include Dashboard, Customers, Programs, Branches, Staff, Notifications, Referrals, Messages, Billing, Profile, Settings, and Scanner.

Can view, search, create, and edit customers; view history, referrals, tiers, public cards; share/copy cards; disable cards and scan tokens. No delete action found.

Can view, create, and edit loyalty programs; enroll customers; manage program customers; create/edit/disable branches; manage Branch Managers and Staff; reset Staff/Branch Manager passwords.

Can open scanner, scan cards, issue stamps, redeem rewards, and use manual token fallback.

Verdict: PASS.

Branch Manager

Pages include Branch dashboard, Business customers, Programs, and Scanner.

Can view/search same-business customers, open customer profiles, enroll customers, view loyalty progress, public card, QR/scan URL, and redemption history. No edit/delete action found.

Can view active business programs and enroll customers. Cannot create, edit, disable, or delete programs.

Can scan cards, issue stamps, redeem rewards, and use manual token fallback. Verdict: PASS WITH WARNINGS because same-business customer visibility is broader than branch-only visibility.

Staff

Pages include Staff dashboard, Enroll customer, Programs, and Scanner.

Can enroll/create customers for assigned branch and open cards after enrollment. Can view active programs. Cannot edit/delete customers or programs.

Can scan cards and issue stamps. Cannot redeem rewards. Verdict: PASS.

Hidden URL and Tenant Isolation

System Administrator routes require platform role. Business Owner routes require business owner context. Branch Manager routes require branch manager role. Staff routes require staff role.

Business Owner queries use businessId. Branch Manager customer access is same-business scoped. Staff enrollment and scanner use assigned businessId and branchId.

Wrong-business scans and redemptions are blocked.

Warning: automated route coverage exists for important groups, but not every nested page individually.

Final Summary Matrix

Feature | System Admin | Business Owner | Branch Manager | Staff

Feature	System Admin	Business Owner	Branch Manager	Staff
Platform admin	Full	No	No	No
Business dashboard	No	Full	No	No
Branch dashboard	No	No	Full	No
Staff dashboard	No	No	No	Full
View customers	Aggregate/no ops	Full business	Same business	Limited
Create customers	No	Yes	Yes	Yes
Edit customers	No	Yes	No	No
Delete customers	No	No action	No	No
Programs	Platform plans only	Create/edit	View/enroll	View only
Referrals	Aggregate/audit	Full center	No center	No center
Users	Platform users	Branch/Staff users	No	No
Scanner/stamps	No	Yes	Yes	Yes
Reward redemption	No	Yes	Yes	No

Billing/subscriptions | Full | Own read-only | No | No
Settings | Platform | Business | No | No